

Security Readiness Checklist

For regulated US SMBs — Healthcare, Legal, Financial

Klaravex · 2026-07 · US Edition

Cover

Security Readiness Checklist

For regulated US SMBs — Healthcare, Legal, Financial

The same 12-point framework Klaravex uses to onboard every new client.

Version: 2026-07 · US Edition

Contact: klaravex.com/readiness-review

Clarity. Security. Results.

Page 1 — How to use this checklist

This checklist maps a regulated small business's security posture across twelve operational domains. Each item is a yes/no question a regulator, an auditor, or a client's procurement office may ask. Answers are self-scored.

Scoring key.

Green — every item in the domain is a confident yes. The organization is likely audit-ready in that domain.

Yellow — controls exist but are undocumented, untested, or applied inconsistently. Real risk lives here.

Red — most items are no. A competent adversary or auditor will exploit the gap.

How to work through it. Read one domain at a time. For each item, mark the checkbox only if the organization can produce written or system-generated evidence today. Verbal confirmation from a vendor or an internal team member is not evidence. If a control exists but the evidence cannot be retrieved within one business day, treat the item as unchecked.

Framework citations. Every item is annotated with the regulatory or standards clause that most directly applies. Citations are shortened for readability; the full text of each clause is available from the issuing

body. Where multiple frameworks apply, the item lists the two most authoritative.

Disclaimer. This document is an operational checklist, not legal, accounting, or compliance advice. It draws on the HIPAA Security Rule (45 CFR Part 164), the AICPA SOC 2 Trust Services Criteria (2017, revised 2022), ISO/IEC 27001:2022 (Annex A controls), and the FTC Standards for Safeguarding Customer Information (16 CFR Part 314, 2023 update). Individual states, licensing boards, and contractual obligations may impose additional requirements. Consult qualified counsel before relying on any item for regulatory attestation.

Page 2 — Domain 1: Governance & policy

Why this matters. Regulators do not begin an examination by inspecting a firewall. They ask for the written program that governs it. A security program without governance is a collection of tools; with governance, it becomes defensible.

- ☐ Written information security program, approved and dated within the last twelve months [HIPAA §164.316(a); FTC Safeguards §314.4(b); ISO 27001 A.5.1]
- ☐ Named security leader — internal or fractional — with documented authority to enforce policy [FTC Safeguards §314.4(a); SOC 2 CC1.3]
- ☐ Risk assessment completed within the last twelve months and mapped to identified information assets [HIPAA §164.308(a)(1)(ii)(A); FTC Safeguards §314.4(c); ISO 27001 Clause 6.1.2]
- ☐ Ownership, board, or managing partner has formally signed off on residual risk [SOC 2 CC3.1; ISO 27001 Clause 5.1]
- ☐ Policies reviewed and reapproved annually, with change history preserved [HIPAA §164.316(b)(2); ISO 27001 A.5.1]

Page 2 — Domain 2: Asset & data inventory

Why this matters. An organization cannot protect what it has not enumerated. Every framework treats an accurate inventory as a foundational control because gaps here cascade into every other domain.

- ☐ Inventory of endpoints, servers, and cloud tenants updated within the last ninety days [FTC Safeguards §314.4(c)(1); ISO 27001 A.5.9]
- ☐ Data classification scheme distinguishing PHI, PII, client-confidential, and public data [HIPAA §164.308(a)(1); SOC 2 CC3.2; ISO 27001 A.5.12]
- ☐ Data flow diagram showing where regulated data enters, is stored, is processed, and leaves the environment [FTC Safeguards §314.4(c)(1); SOC 2 CC3.2]
- ☐ Software inventory identifying all applications with access to regulated data [ISO 27001 A.5.9; SOC 2 CC6.1]

Page 3 — Domain 3: Access control & identity

Why this matters. Credential compromise remains the most common initial access vector in reported breaches. Identity is now the perimeter, and access reviews are the evidence auditors ask for first.

- ☐ Multi-factor authentication enforced on every user account with email, file, or system access [HIPAA §164.312(d); FTC Safeguards §314.4(c)(5); SOC 2 CC6.6]
- ☐ Privileged access reviewed at least quarterly, with least-privilege documented [HIPAA §164.308(a)(4); SOC 2 CC6.3; ISO 27001 A.5.15]
- ☐ Off-boarding process removes access to email, files, and systems within four hours of separation [HIPAA §164.308(a)(3)(ii)(C); SOC 2 CC6.2; ISO 27001 A.5.11]
- ☐ Unique, non-shared credentials for every user; service accounts inventoried and rotated [HIPAA §164.312(a)(2)(i); SOC 2 CC6.1]
- ☐ Session timeouts and re-authentication requirements enforced on systems handling regulated data [HIPAA §164.312(a)(2)(iii); ISO 27001 A.8.5]

Page 3 — Domain 4: Endpoint & network defense

Why this matters. Signature-based antivirus does not detect modern intrusions. Regulators and cyber insurers increasingly ask specifically about endpoint detection and response with a monitored escalation path.

- ☐ Endpoint detection and response — not signature antivirus alone — deployed on every endpoint with a monitored 24/7 escalation path [FTC Safeguards §314.4(c)(4); SOC 2 CC7.2; ISO 27001 A.8.7]
- ☐ Patch management program with documented cadence; critical CVEs remediated within fourteen days [HIPAA §164.308(a)(5)(ii)(B); FTC Safeguards §314.4(c)(6); ISO 27001 A.8.8]
- ☐ Network segmentation separating client-facing systems from administrative and finance systems [FTC Safeguards §314.4(c)(1); ISO 27001 A.8.22]
- ☐ DNS filtering and email security gateway with active threat blocking, tuned within the last twelve months [FTC Safeguards §314.4(c)(4); SOC 2 CC6.8]
- ☐ Wireless networks separated between guest, staff, and administrative use, with WPA3 or enterprise authentication [ISO 27001 A.8.20; SOC 2 CC6.6]

Page 4 — Domain 5: Backup & recovery

Why this matters. Ransomware is only survivable when backups are immutable and restores are tested. Untested backups are a hope, not a control, and neither auditors nor insurers accept them as one.

- ☐ Immutable or write-once backups covering every regulated data store [FTC Safeguards §314.4(c)(8); SOC 2 A1.2; ISO 27001 A.8.13]
- ☐ Restore test performed within the last ninety days with a written result retained as evidence [HIPAA §164.308(a)(7)(ii)(D); SOC 2 A1.3; ISO 27001 A.8.13]
- ☐ Documented recovery time objective and recovery point objective for each regulated system [HIPAA §164.308(a)(7)(ii)(B); SOC 2 A1.2]
- ☐ Backup copies stored in a location logically and physically isolated from production [FTC Safeguards §314.4(c)(8); ISO 27001 A.8.13]
- ☐ Backup credentials protected with separate authentication from primary administrative accounts [SOC 2 CC6.1; ISO 27001 A.8.13]

Page 4 — Domain 6: Vendor & third-party risk

Why this matters. Regulated data handled by a vendor remains the organization's regulatory responsibility. Every recent enforcement action against a small firm has included a failure to oversee at least one vendor.

- ☐ Vendor inventory with data-handling classification for each vendor that touches regulated data [FTC Safeguards §314.4(f); ISO 27001 A.5.19]
 - ☐ Business Associate Agreements executed and dated for every HIPAA-covered vendor [HIPAA §164.308(b)(1); §164.314(a)]
 - ☐ Annual review of critical vendors' SOC 2 Type II reports or equivalent independent assurance [FTC Safeguards §314.4(f)(3); SOC 2 CC9.2]
 - ☐ Contractual security requirements — breach notification, data return, sub-processor disclosure — present in every vendor agreement handling regulated data [FTC Safeguards §314.4(f)(2); ISO 27001 A.5.20]
 - ☐ Vendor off-boarding process confirms return or destruction of regulated data [HIPAA §164.314(a)(2)(i)(D); ISO 27001 A.5.20]
-

Page 5 — Domain 7: Incident response

Why this matters. The window between detection and notification is measured in hours by most breach notification statutes. A plan that lives only in a slide deck fails at exactly the wrong moment.

- ☐ Written incident response plan naming roles, decision-makers, and current phone numbers [HIPAA §164.308(a)(6); FTC Safeguards §314.4(h); SOC 2 CC7.4]
- ☐ Tabletop exercise performed within the last twelve months with documented gaps and remediation status [FTC Safeguards §314.4(h)(2); SOC 2 CC7.4; ISO 27001 A.5.24]
- ☐ 24/7 escalation path to a competent responder — internal team or contracted partner [FTC Safeguards §314.4(c)(4); SOC 2 CC7.3]
- ☐ Breach notification decision tree mapped to applicable state, federal, and contractual timelines [HIPAA §164.404; §164.410; FTC Safeguards §314.5]
- ☐ Post-incident review process producing corrective actions and a retained written record [HIPAA §164.308(a)(6)(ii); SOC 2 CC7.5; ISO 27001 A.5.27]

Page 5 — Domain 8: Training & phishing

Why this matters. Phishing remains the most reliable path into a small business. Untrained staff — including partners and executives — are the most exploited asset in the environment.

- ☐ Annual security awareness training completed by every user, with attestation retained [HIPAA §164.308(a)(5)(i); FTC Safeguards §314.4(e); SOC 2 CC1.4]
- ☐ Quarterly phishing simulation with click-rate and reporting-rate tracked over time [FTC Safeguards §314.4(e); ISO 27001 A.6.3]
- ☐ New-hire security orientation delivered within the first thirty days of employment [HIPAA §164.308(a)(5)(i); ISO 27001 A.6.3]
- ☐ Role-specific training for administrators, developers, and staff with elevated data access [FTC Safeguards §314.4(e); ISO 27001 A.6.3]

Page 6 — Domain 9: Encryption & data protection

Why this matters. Encryption is one of the few controls that materially reduces breach notification exposure. Where implemented correctly, it converts a reportable event into a non-reportable one under several state statutes.

- ☐ Full-disk encryption enabled and verified on every endpoint holding regulated data [HIPAA §164.312(a)(2)(iv); FTC Safeguards §314.4(c)(3); ISO 27001 A.8.24]
- ☐ TLS 1.2 or higher enforced on every external service; deprecated protocols disabled [HIPAA §164.312(e)(1); ISO 27001 A.8.24]
- ☐ Cloud storage encryption at rest verified per tenant, with key management documented [FTC Safeguards §314.4(c)(3); SOC 2 CC6.7; ISO 27001 A.8.24]

- ☐ Removable media policy restricting or encrypting portable storage carrying regulated data [HIPAA §164.310(d)(1); ISO 27001 A.7.10]
- ☐ Email encryption available and used for outbound messages containing regulated data [HIPAA §164.312(e)(2)(ii); FTC Safeguards §314.4(c)(3)]

Page 6 — Domain 10: Physical & remote work

Why this matters. Regulated data now lives on kitchen tables. Physical safeguards apply wherever work happens, and remote work is where most small firms have the least documentation.

- ☐ Office access controlled with badge, code, or key management; visitor log maintained [HIPAA §164.310(a)(1); ISO 27001 A.7.2]
- ☐ Written remote-work security policy covering device use, network security, and printed material [HIPAA §164.310(d)(1); FTC Safeguards §314.4(c); ISO 27001 A.6.7]
- ☐ Company-managed devices required for regulated data; personal-device use restricted to non-regulated flows [FTC Safeguards §314.4(c)(1); ISO 27001 A.8.1]
- ☐ Secure disposal process for paper records and end-of-life hardware, with certificates retained [HIPAA §164.310(d)(2); ISO 27001 A.7.14]
- ☐ Clean-desk expectation documented for locations processing regulated data [ISO 27001 A.7.7]

Page 7 — Domain 11: Monitoring & audit

Why this matters. Without logs, an incident cannot be scoped, reported accurately, or defended in litigation. Every mature framework requires central log collection and human review.

- ☐ Central log collection covering identity, endpoint, cloud, and email sources [HIPAA §164.312(b); FTC Safeguards §314.4(c)(8); SOC 2 CC7.2]
- ☐ Alerts routed to a human responder who acts within one hour, 24/7 [FTC Safeguards §314.4(c)(4); SOC 2 CC7.2]
- ☐ Log retention period documented and meeting the longest applicable regulatory or contractual requirement [HIPAA §164.316(b)(2); SOC 2 CC7.2; ISO 27001 A.8.15]
- ☐ Periodic review of audit logs by someone other than the administrator who generated them [HIPAA §164.308(a)(1)(ii)(D); SOC 2 CC4.1]
- ☐ Change management records demonstrating who changed what, when, and with whose approval [SOC 2 CC8.1; ISO 27001 A.8.32]

Page 7 — Domain 12: Compliance mapping & evidence

Why this matters. Controls without documented mapping are invisible in an audit. The organizations that pass client due-diligence questionnaires quickly are the ones with evidence organized in advance.

- ☐ Every control mapped to at least one regulatory framework — HIPAA, SOC 2, ISO 27001, or FTC Safeguards [FTC Safeguards §314.4(b); SOC 2 CC3.1; ISO 27001 Clause 6.1]
- ☐ Evidence repository containing dated policies, screenshots, and test results, retrievable within one business day [HIPAA §164.316(b)(1); SOC 2 CC4.2; ISO 27001 A.5.37]
- ☐ Client and prospect security questionnaires answered within five business days of receipt [SOC 2 CC2.3]
- ☐ Annual written report to ownership or the board summarizing program status, incidents, and material changes [FTC Safeguards §314.4(i); SOC 2 CC4.2]
- ☐ Corrective action tracker maintained for open findings from internal reviews, audits, and incidents [SOC 2 CC4.2; ISO 27001 A.10.1]

Page 8 — Score yourself

Add one point for each checked item. There are between fifty-four and sixty items depending on how sub-items were counted; the scoring bands below are calibrated against a nominal forty-eight-item baseline so that partial credit for adjacent items does not distort the result.

40 to 48 checkmarks — Audit-ready. The organization can withstand a regulatory examination, a client due-diligence review, or a cyber insurance underwriting question with existing evidence. Focus shifts to sustaining the program and closing residual documentation gaps.

30 to 39 checkmarks — Real program with gaps. Governance and tooling are in place, but at least one domain would fail an examination on documentation, testing, or consistency. Prioritize the lowest-scoring domain, not the newest tool.

20 to 29 checkmarks — Tools without a program. The organization has purchased security capability but has not tied it into a program a regulator would recognize. This is the most common state for regulated small firms and the one most exposed at renewal or during procurement review.

0 to 19 checkmarks — Exposure. A single incident becomes existential — regulatorily, financially, and reputationally. Immediate action is warranted on governance, access control, backup integrity, and incident response before any further tooling investment.

A yellow score across half the domains is more common than a red one, and less obvious. It is also the state that most reliably produces a bad outcome under examination, because the organization believes it is protected and the evidence does not support the belief.

Page 9 — The gap the checklist reveals

Most regulated small businesses score yellow across half of these twelve domains. They own the tools — endpoint detection, cloud backup, a password manager, a phishing platform — but the tools have not been tied into a program that a regulator, an auditor, or a client's procurement office would recognize.

The gap is not technical. It is programmatic. It shows up as a policy that has not been reviewed in three years, a restore test that was never documented, a vendor list that lives in one partner's memory, an incident response plan that names a phone number that has been disconnected for a year. Each item is small. Together they are the reason enforcement actions against small firms consistently cite documentation failures, not technology failures.

Klaravex builds and runs the program. Readiness advisory that produces the written artifacts a regulator expects. Managed detection and response that gives the endpoint stack a human on the other end at three in the morning. A named security leader — fractional where the firm does not need a full-time hire — with the authority to enforce policy and the accountability to report to ownership. Delivered as one service, under one contract, with one point of accountability.

The tools already purchased continue to be used. The gap that gets closed is the one between owning them and being able to prove they work.

Page 10 — Next step

Book a thirty-minute readiness review.

A Klaravex advisor walks the twelve-domain checklist with the organization's designated lead, records the score, identifies the two highest-risk items, and produces a written estimate of what closing them costs. The review is delivered under a mutual non-disclosure agreement. No sales presentation, no obligation to proceed.

Schedule at **klaravex.com/readiness-review**, or reply to this download and a scheduling link will be sent within one business day.

Clarity. Security. Results.

US-owned. US-delivered. Regulated SMB focused.